risks and will assist covered institutions in formulating and improving their security standards. Another commenter suggested the proposed definition might be too narrow because it includes the separate concept of substantial harm or inconvenience in the definition, resulting in under-notification.[124] This commenter stated that harms can take many forms, and customers should receive notice of breaches involving customer information even where that information's compromise might not have obvious financial implications to the customer.

Conversely, a number of commenters asserted that the proposed definition was too broad and could lead to over-notification, suggesting that the definition be narrowed to focus on information whose exposure would be more likely to lead to tangible economic harms.[125] For example, some commenters suggested that, rather than providing examples, the definition should list specific data elements that, when combined with an individual's name, are sufficiently sensitive to require notification.[126] These commenters focused on those data elements that could be used to commit identity theft or access the customer's financial account, such as a Social Security number, driver's license or state ID number, or financial account number combined with information necessary to access the account. According to one of these commenters, by using illustrative examples rather than a circumscribed list, covered institutions would face uncertainty over the definition's meaning and would likely err on the side of over-inclusion, which could lead to over-notification.[127] A number of commenters stated that narrowing the definition would be more consistent with the Banking Agencies' Incident Response Guidance

---

124 *See* EPIC Comment Letter.

125 *See, e.g.*, CAI Comment Letter; IAA Comment Letter 1; SIFMA Comment Letter 2; ICI Comment Letter 1.

126 *See* CAI Comment Letter; SIFMA Comment Letter 2.

127 *See* CAI Comment Letter.

and with various state laws.[128] One commenter also suggested the proposed use of the term "compromise" in the definition was unclear, and should be replaced with "unauthorized access or use," consistent with other authorities and language used elsewhere in the proposal.[129]

After considering these comments, we are adopting the definition of "sensitive customer information" as proposed. We recognize that this definition is broader than that used by some states and the Banking Agencies' Incident Response Guidance.[130] However, in contrast to the narrower definition used in some states, the definition of sensitive customer information we are adopting includes identifying information that, in combination with authenticating information (such as a partial Social Security number, access code, or mother's maiden name), could create a substantial risk of harm or inconvenience to the customer because they may be widely used for authentication purposes.[131] Similarly, in contrast to the definition provided in the Banking Agencies' Incident Response Guidance (which includes a customer's name, address, or telephone number, only in conjunction with other pieces of information that would permit access to a customer account), the definition in the Commission's final amendments includes customer information identified with an individual (such as Social Security numbers, driver's license numbers, biometric records) that, without any other identifying information, could create a substantial risk of harm or inconvenience to an individual identified with the information.[132]

---

128 *See, e.g.*, SIFMA Comment Letter 2; Computershare Comment Letter; CAI Comment Letter.

129 *See* CAI Comment Letter.

130 *See* Proposing Release at nn.113 and 115 (describing the differences). *But see id.* at n.115, stating that a number of states define the scope of personal information subject to a notification obligation in a manner that generally aligns with the definition of sensitive customer information under these final rules.

131 *See infra* footnote 810 and surrounding text (discussing that 14 states more narrowly define the kind of information that trigger notice requirements than our adopted definition of sensitive customer information in that only the compromise of a customer's name together with one or more enumerated pieces of information triggers the notice requirement).

132 *See* Proposing Release at n.114 and accompanying text, stating that Social Security numbers alone, without any other information linked to the individual, are sensitive because they have been used by malicious

Accordingly, our adopted definition could help affected individuals take measures to protect themselves.

Given the varied and evolving nature of security practices across covered institutions, it would be impractical to provide an exhaustive list of data elements whose exposure could put affected individuals at risk of substantial harm or inconvenience. Further, while we are mindful of concerns about overbreadth and potential over-notification, those concerns are tempered by the definition's harm component and the ability of covered entities to rebut the notification presumption following a reasonable investigation and determination. Given these considerations, we are not broadening the definition of sensitive customer information to encompass information whose exposure does not pose a reasonably likely risk of substantial harm or inconvenience. Nor do we agree that the definition's use of the verb "compromise," which is commonly used to mean "to expose or make liable to danger," is ambiguous in this context or inconsistent with other federal authorities.[133] Individuals are less likely to need to take protective measures in cases where the exposure of their information is not likely to involve a substantial harm or inconvenience.[134]

Finally, several commenters suggested we include an exception or safe harbor in the definition of sensitive customer information for encrypted information.[135] These commenters

---

actors in "Social Security number-only" or "synthetic" identity theft, to open new financial accounts, and that a similar sensitivity exists with other types of identifying information that can be used alone to authenticate an individual's identity such as a biometric record of a fingerprint or iris image.

133 *See, e.g.*, Harmonization of Cyber Incident Reporting to the Federal Government, Homeland Security Office of Strategy, Policy, and Plans, Appendix B: Federal Cyber Incident Reporting Requirements Inventory (Sept. 10, 2023) (summarizing cyber incident reporting regulations of multiple agencies that use the term "compromise," including Departments of Defense, Justice, and Energy, the Federal Communications Commission, the Nuclear Regulatory Commission, and the Federal Energy Regulatory Commission).

134 *See infra* section II.A.3.c.

135 *See* AWS Comment Letter; Google Comment Letter; IAA Comment Letter 1; SIFMA Comment Letter 2.

stated that excepting encrypted information would protect customers by incentivizing covered institutions to adopt encryption practices, limit the potential for voluminous over-reporting of less severe incidents, and align with existing state data breach notification rules. Some of these commenters acknowledged that an exception should not apply in cases where there is reason to believe that the encryption key has been compromised or that the encryption method is outdated.[136] One commenter suggested that if we did not include an exception in the rule text, we should acknowledge that encryption is a factor that covered institutions may take into account in determining whether an incident will result in substantial harm or inconvenience.[137]

After considering these comments, we are not excepting encrypted information from the rule's definition of sensitive customer information because the rule text effectively addresses encrypted information without the need for a provision specifically tailored to that information. Specifically, in applying the final rule, a covered institution may consider encryption as a factor in determining whether the compromise of customer information could create a reasonably likely harm risk to an individual identified with the information.[138] Specifically, we acknowledge that encryption of information using current industry standard best practices is a reasonable factor for a covered institution to consider in making this determination. To the extent such encryption minimizes the likelihood that the cipher text could be decrypted, it would also reduce the likelihood that the cipher text's compromise could create a risk of harm, as long as the associated decryption key is secure.[139] Covered institutions may also reference commonly used

---

136 *See* Google Comment Letter, IAA Comment Letter 1; SIFMA Comment Letter 2.

137 *See* IAA Comment Letter 1.

138 *See* Proposing Release at n.116 and accompanying text.

139 As discussed in the Proposing Release, most states except encrypted information in certain circumstances, including, for example, where the covered institution can determine that the encryption offers certain levels of protection or the decryption key has not also been compromised. *See* Proposing Release at n.117 and accompanying text.

cryptographic standards to determine whether encryption, in fact, does substantially impede the likelihood that the cipher text's compromise could create a risk of harm.[140] As industry standards continue to develop in the future, covered institutions generally should review and update, as appropriate, their encryption practices. While we agree with commenters that it is important to incentivize the use of encryption consistent with state law regimes, the final amendments' approach accomplishes this goal while also addressing concerns that any particular approach to encryption may become outdated as technologies and security practices evolve. Relatedly, and for the same reasons, when information that would otherwise constitute sensitive customer information is encrypted, the covered institution may consider the security provided by that encryption in determining whether the cipher text (i.e., the data rendered in a format not understood by people or machines without an encryption key) is sensitive customer information. Accordingly, while the final amendments provide illustrative examples of information (such as a customer's Social Security number) that can constitute sensitive customer information when unencrypted,[141] a covered institution could nevertheless determine that the encrypted representation of that information is not sensitive customer information if the encryption renders the cipher text sufficiently secure, such that the compromise of that encrypted information does not create a reasonably likely risk of substantial harm or inconvenience to an individual.[142]

---

140 We understand that standards included in Federal Information Processing Standard Publication 140-3 (FIPS 140-3) are widely referenced by industry participants. *See* Proposing Release at n.118.

141 *See* final rule 248.30(d)(9)(ii)(A)(*1*) through (*4*) and 248.30(d)(9)(ii)(B).

142 To the extent a covered institution's determination about the security of cipher text affects its determination about whether notice of a breach is required under the final rules, the covered institution would be required to make and maintain written documentation of that determination. *See* final rule 248.30(c)(1)(iii).

c. Substantial Harm or Inconvenience

The GLBA directs the Commission and other Federal financial regulators to, among other things, establish appropriate standards requiring financial institutions subject to their jurisdiction to protect against unauthorized access to or use of customer records or information which could result in "substantial harm or inconvenience" to any customer, without defining what constitutes a substantial harm or inconvenience under the statute.[143] The Commission proposed to define "substantial harm or inconvenience" to mean all personal injuries, as well as instances of financial loss, expenditure of effort, or loss of time when they are "more than trivial," with the proposal also providing a non-exhaustive list of examples of included harms or inconveniences.[144] This proposed definition included a broad range of financial and non-financial harms and inconveniences that may result from the failure to safeguard sensitive customer information.[145] After considering comments, and as discussed further below, we have determined not to define the term "substantial harm or inconvenience" in the final amendments.

Commenters raised various concerns with the proposed definition. Some commenters proposed expanding the definition to include a broader array of harms requiring notification.[146] For example, one commenter suggested revising it to enumerate a list of specific personal injuries requiring notification to help clarify to covered institutions that there are a range of personal injuries that can result from an exposure of customer data.[147] Commenters also

---

143 *See* 15 U.S.C. 6801(b). The Banking Agencies' Incident Response Guidance likewise does not define the term "substantial harm or inconvenience."

144 *See* proposed rule 248.30(e)(11).

145 *See* Proposing Release at n.124.

146 *See* EPIC Comment Letter; NASAA Comment Letter; Better Markets Comment Letter.

147 *See* EPIC Comment Letter (suggesting the definition specifically list as examples of personal injuries: theft, fraud, harassment, physical harm, psychological harm, impersonation, intimidation, damaged reputation, impaired eligibility for credit or government benefits, or the misuse of information identified with an

suggested we remove the requirement that personal or financial harms be nontrivial because, according to these commenters, there might always be some set of individuals to whom a particular personal or financial harm is material, and securities firms are not well positioned to determine what potential personal or financial harms to their customers are significant enough to require customer notice.[148] One of these commenters observed that, while it made sense to apply the concept of nontriviality to potential harms or inconveniences that would infringe upon a customer's time and personal labors, risks to the customer's person and pocketbook are materially different from risks to the customer's time and energies.[149] This commenter also suggested broadening the definition to include the term "cyberattack" as one of the enumerated events that could give rise to the customer notice obligation.

Alternatively, a number of commenters suggested that the proposed standard was ambiguous and urged narrowing the definition to reduce the types of injuries that would require notification.[150] For example, one commenter suggested that we not attempt to define "substantial harm or inconvenience" at all, and further expressed concern that the proposed definition would require notice for harms or inconveniences that are unrelated to identify theft, the means to access an account without authority, or other "tangible harms."[151] Another commenter proposed narrowing the kinds of financial loss or time and effort cognizable under the rules from "more than trivial" to only "material" financial loss or "significant" expenditure of effort or loss of

---

individual to obtain a financial product or service, or to access, log onto, effect a transaction in, or otherwise misuse the individual's account).

148 *See* NASAA Comment Letter; EPIC Comment Letter (agreeing with NASAA's comment).

149 *See* NASAA Comment Letter.

150 *See, e.g.*, Comment Letter of Cambridge ("Cambridge Comment Letter"); CAI Comment Letter; IAA Comment Letter 1; SIFMA Comment Letter 2.

151 *See* SIFMA Comment Letter 2.

time, suggesting that the proposed definition would be inconsistent with the usual meaning of the term "substantial" and could include any financial loss that is slightly above trivial as substantial.[152] Another commenter stated that the use of "more than trivial" set a very low bar that could result in second-guessing and over notification by covered intuitions that could lead to notification in practically all instances, not just instances of what the commenter viewed as a substantial harm or inconvenience.[153] This commenter also stated that, as drafted, it was unclear whether the proposed "more than trivial" standard was meant to apply to instances of personal injury or financial loss and suggested replacing "more than trivial" with substantial, while making clear that the word substantial modified all elements of the definition. Other commenters suggested narrowing the proposed definition by removing the term "inconvenience" from the definition, with notification only required in cases of substantial harm that were more than trivial.[154]

After considering comments, we have determined, consistent with the approach of the Banking Agencies, not to define the term "substantial harm or inconvenience." As the range of commenter concerns discussed above reflects, commenters found the proposed definition simultaneously too broad and too narrow, suggesting it could consequently lead to both under-notification and over-notification. Eliminating the proposed definition avoids this result without diminishing investor protection.

Determining whether a given harm or inconvenience rises to the level of a substantial harm or a substantial inconvenience would depend on the particular facts and circumstances

---

152 *See* IAA Comment Letter 1.

153 *See* CAI Comment Letter ("it is hard to imagine any instance of unauthorized access or use of customer information that could not create a reasonably likely risk of more than trivial inconvenience, and therefore not require notification").

154 *See* Cambridge Comment Letter; Financial Services Institute Comment Letter.

surrounding an incident. As stated in the Proposing Release, we do not intend for covered institutions to design programs and incur costs to protect customers from harms of such trivial significance that the customer would be unconcerned with remediating them.[155] At the same time, consistent with the GLBA, the rules are intended to protect against unauthorized access to or use of customer records or information which could result in substantial harm or inconvenience to any customer. Given the wide variety of ways that a data breach can injure a customer,[156] and the potentially varied nature of those harms and inconveniences,[157] the range of harms outlined in the proposed definition may be a useful starting point for this determination. A personal injury, financial loss, expenditure of effort, or loss of time, each could constitute a substantial harm or inconvenience depending on the particular facts and circumstances. Some examples of these harms could include theft, fraud, harassment, physical harm, impersonation, intimidation, damaged reputation, impaired eligibility for credit, or the misuse of information identified with an individual to obtain a financial product or service, or to access, log into, effect a transaction in, or otherwise misuse the individual's account.

d. Timing Requirements

(1) General Timing Requirements

Consistent with the proposal, the final amendments require covered institutions to provide notices to affected individuals as soon as practicable, but not later than 30 days, after becoming aware that unauthorized access to or use of customer information has occurred or is reasonably likely to have occurred, except under the limited circumstances discussed below.[158]

---

155 *See* Proposing Release at Section II.A.4.c.

156 *See* Proposing Release at n.124.

157 *See*, *e.g.*, NASAA Comment Letter; IAA Comment Letter 1.

158 *See* final rule 248.30(a)(4)(iii); *see also* section II.A.3.d(2) (discussing the national security and public

This approach reflects the goal of giving covered institutions adequate time to make an initial assessment of an incident and prepare and send notices to affected individuals, while helping to ensure that those individuals receive sufficient notice to protect themselves.

A few commenters expressed support for the proposed notification timing requirements.[159] As described above, these commenters viewed timeliness as important because any delay in notification could impact individuals' ability to take steps to protect themselves from the downstream impacts resulting from the unauthorized access to or use of their sensitive customer information.[160] One commenter asserted that 30 days after becoming aware of an incident is more than an ample amount of time for covered institutions to determine the scope of the compromised information and compile a list of affected customers that must be notified.[161] Accordingly, this commenter suggested that the Commission should shorten the outside notification date from 30 days after becoming aware of a data security incident to 14 days, asserting that the longer an instance of identity theft goes undetected, the greater the damage that usually follows.

In contrast, some commenters objected to the proposed notification timing requirements because, in their view, it provided an insufficient amount of time to notify affected individuals.[162] These commenters emphasized the logistical tasks associated with responding to an information breach, asserting that in some cases it would be impossible to accomplish these steps within 30

---

safety delay to the notification timing requirements).

159 EPIC Comment Letter; Better Markets Comment Letter.

160 *See supra* section II.A.3.a.

161 Better Markets Comment Letter.

162 *See*, *e.g.*, SIFMA Comment Letter 2; IAA Comment Letter 1; FSI Comment Letter; NASDAQ Comment Letter; CAI Comment Letter.